

VULNERABILITY ASSESSMENT REPORT

**TARGET WEBSITE:
OWASP JUICE SHOP
[HTTPS://OWASP-JUICE.SHOP](https://owasp-juice.shop)**

**PREPARED BY:
ANANYA ACHALENDRAN**

**FUTURE INTERNS-CYBER SECURITY
INTERNSHIP**

DATE: JUNE 2026

EXECUTIVE SUMMARY

This Vulnerability Assessment was conducted on the OWASP Juice Shop web application using passive and non-intrusive security testing techniques.

The objective of the assessment was to identify publicly visible security weaknesses without performing exploitation or unauthorized access attempts.

The assessment included port discovery, security header inspection, and passive vulnerability analysis using industry-standard tools such as Nmap, OWASP ZAP, and browser developer tools.

Several findings were identified, including exposed services, missing security configurations, and caching-related observations. Recommendations have been provided to reduce risk and improve the overall security posture of the application.

SCOPE & METHODOLOGY

Scope

Target Website: <https://owasp-juice.shop>

Assessment Type:

Read-Only Vulnerability Assessment

Restrictions:

- No exploitation performed
- No brute-force attacks performed
- No denial-of-service testing performed
- No unauthorized access attempts performed

Tools Used

- Nmap
- OWASP ZAP (Passive Scan)
- Microsoft Edge Developer Tools

Methodology

1. Identified exposed network services using Nmap.
2. Inspected HTTP security headers using browser developer tools.
3. Performed passive vulnerability analysis using OWASP ZAP.
4. Documented findings and assessed risk levels.
5. Provided remediation recommendations.

NMAP RESULTS

Port Scan Results

Port	Service	Status
21	FTP	Open
25	SMTP	Filtered
80	HTTP	Open
443	HTTPS	Open
8080	HTTP Proxy	Open

Observation

Multiple publicly accessible services were identified. Exposed services increase the attack surface and should be reviewed regularly to ensure only required services remain accessible.

FINDINGS

Finding F-01

FTP Service Exposed

Risk Level: Medium

Description

The FTP service was found accessible on Port 21 during the Nmap scan.

Impact

Publicly accessible FTP services can increase exposure to unauthorized access attempts and potential misconfigurations.

Recommendation

Disable FTP if unnecessary or replace it with secure alternatives such as SFTP or FTPS.

Finding F-02

Additional Web Service Exposed

Risk Level: Low

Description

An additional web service was identified on Port 8080.

Impact

Additional services increase the attack surface and require proper monitoring and configuration.

Recommendation

Review the necessity of the service and restrict access where appropriate.

Finding F-03

Strict-Transport-Security Header Not Set

Risk Level: Low

Description

OWASP ZAP identified the absence of the HTTP Strict Transport Security (HSTS) header.

Impact

Without HSTS, browsers may not always enforce secure HTTPS communication.

Recommendation

Configure the web server to implement the Strict-Transport-Security header.

Finding F-04

Retrieved From Cache

Risk Level: Informational

Description

The response was retrieved from a cache mechanism.

Impact

Sensitive information could potentially be exposed if caching policies are not configured correctly.

Recommendation

Apply appropriate Cache-Control, Pragma, and Expires headers for sensitive content.

RISK MATRIX

Finding	Risk
FTP Service Exposed	Medium
Additional Web Service Exposed	Low
Strict-Transport-Security Header Not Set	Low
Retrieved From Cache	Informational

CONCLUSION

The assessment identified several low-risk and informational security observations along with one medium-risk exposure related to publicly accessible services.

No active exploitation was performed during this assessment.

Implementing the recommended security controls will help improve security posture, reduce attack surface, and align the application with industry best practices.

EVIDENCE

Nmap Scan Screenshot

```
C:\windows\system32\cmd.exe x Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\ANANYA> nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: i686-pc-windows-windows
Compiled with: nmap-liblua-5.4.8 openssl-3.0.16 nmap-libssh2-1.11.1 nmap-libz-1.3.2 nmap-libpcap-1.0.4 Npcap-1.87 nmap-libnet-1.18.0 ipv6
Compiled without:
Available nsock engines: iocp poll select
PS C:\Users\ANANYA> nmap -p- owasp-juice.shop
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-16 20:56 +0530
Nmap scan report for owasp-juice.shop (81.169.145.156)
Host is up (0.21s latency).
Other addresses for owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::
rDNS record for 81.169.145.156: w9c.rzone.de
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
25/tcp    filtered smtp
80/tcp    open  http
443/tcp   open  https
8080/tcp   open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 14.97 seconds
PS C:\Users\ANANYA>
```

Security Headers Screenshot

OWASP Juice Shop

Watch 179 Star 13,352

Main Overview News Challenges Learning CTF Ecosystem Supporters

For the latest information about OWASP Juice Shop visit <https://owasp-juice.shop/>

OWASP Juice Shop is probably the most modern and sophisticated insecure web application! It can be used in security trainings, awareness demos, CTFs and as a guinea pig for security tools! Juice Shop encompasses vulnerabilities from the entire [OWASP Top Ten](#) along with many other security flaws found in real-world applications!

This website uses cookies to analyze our traffic and only share that information with our analytics partners.

The OWASP® Foundation

works to improve the security of software through its community-led open source software projects, hundreds of chapters worldwide, tens of thousands of members, and by hosting local and global conferences.

Project Information

Flagship Project

Classification

Tool

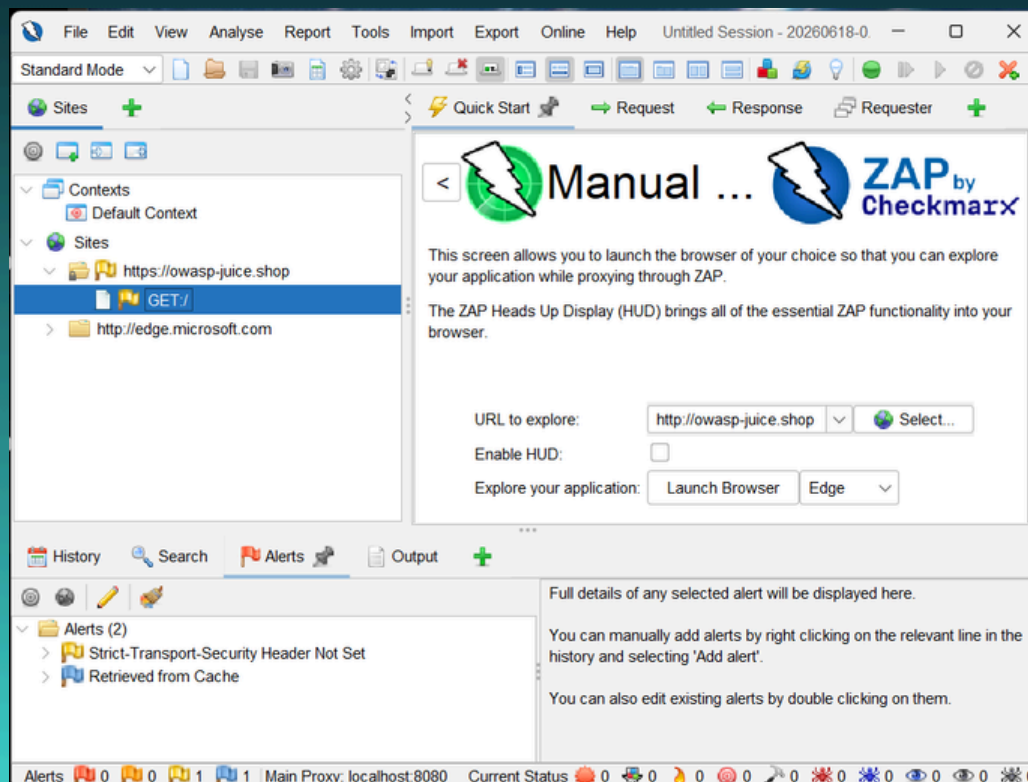
Audience

Builder
Breaker
Defender

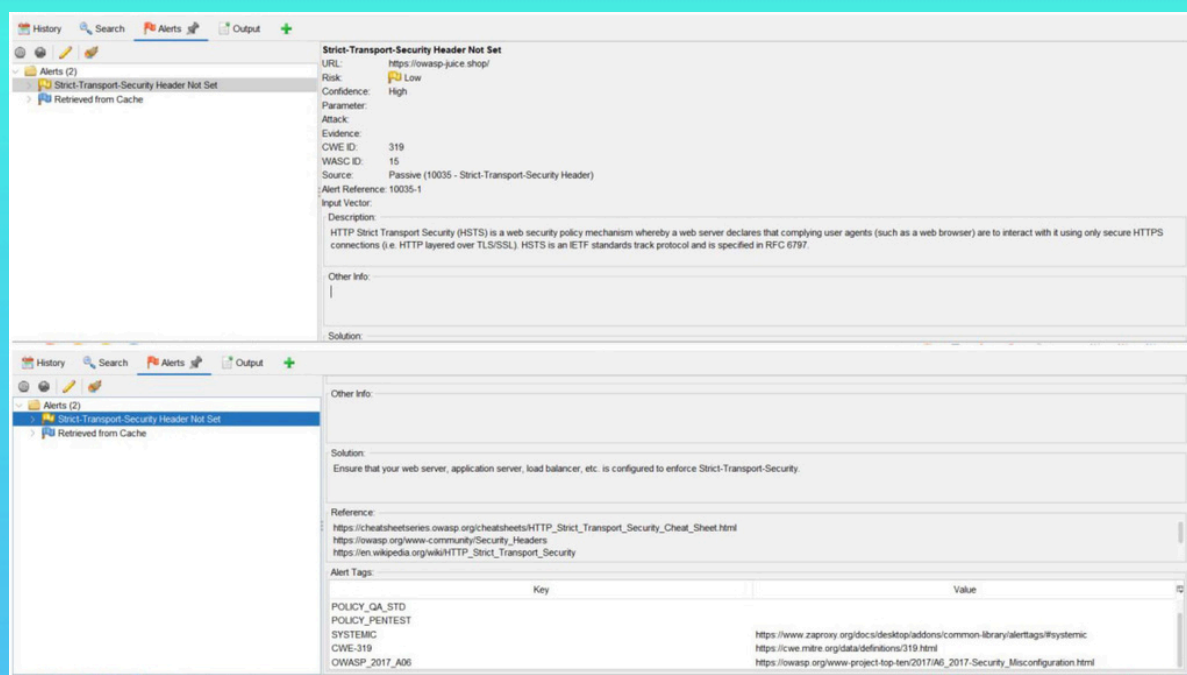
Security Headers

Header	Value
Date	Wed, 17 Jun 2026 19:04:22 GMT
Etag	W/"6a2e48df-17a66"
Expires	Wed, 17 Jun 2026 16:38:04 GMT
Permissions-Policy	geolocation=(self)
Referrer-Policy	same-origin
Server	cloudflare
Strict-Transport-Security	max-age=31536000; includeSubDomains
Vary	Accept-Encoding
Via	1.1 varnish
X-Cache	HIT
X-Cache-Hits	1
X-Content-Type-Options	nosniff
X-Fastly-Request-Id	32557402157648f6b666726a62deb214575c8
X-Frame-Options	SAMEORIGIN
X-Served-By	cache-maa10233-MAA
X-Timer	S1781723062.281595.V5QVE1

ZAP Alerts Screenshot



HSTS Alert Screenshot



Retrieved From Cache Screenshot

The screenshot displays the Burp Suite application window. The 'Alerts' tab is active, showing a list of alerts on the left. The selected alert, 'Retrieved from Cache', is detailed in the main pane. The alert information includes:

- URL:** <https://owasp-juice.shop/>
- Risk:** Informational
- Confidence:** Medium
- Parameter:**
- Attack:**
- Evidence:** HIT
- CWE ID:** 525
- WASC ID:**
- Source:** Passive (10050 - Retrieved from Cache)
- Alert Reference:** 10050-1
- Input Vector:**

Description:

The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

Other info:

Solution:

Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:

Cache-Control: no-cache, no-store, must-revalidate, private

Reference:

<https://datatracker.ietf.org/doc/html/rfc7234>
<https://datatracker.ietf.org/doc/html/rfc7231>

The bottom status bar shows 'Alerts: 0 0 0 1 1' and 'Main Proxy: localhost:8080'. The 'Current Status' bar on the right shows various icons and counts.